GUÍA DE LABORATORIO: IMPLEMENTACIÓN DE IAM EN LINUX (VIRTUALBOX)

Diseño de Matriz de Accesos, Configuración Práctica de Roles y Comandos de Consola

1. Introducción y Marco Teórico de IAM

La Gestión de Identidades y Accesos (IAM por sus siglas en inglés, *Identity and Access Management*) es un concepto integrador en ciberseguridad que permite definir centralizadamente **quién** puede acceder a **qué recursos, bajo qué condiciones** y con qué privilegios dentro de una organización. IAM comprende el ciclo de vida de las identidades digitales, la autenticación y los mecanismos lógicos de autorización. No se limita a un único protocolo o tecnología, sino que coordina directivas operacionales, legales y técnicas para mitigar brechas de seguridad provocadas por privilegios excesivos o accesos fuera de control.

Tres Dimensiones Fundamentales de Seguridad:

• **Identidad digital:** Es el conjunto de atributos unívocos (nombre, legajo, área, nivel de autorización) que describen a una entidad (persona, proceso o dispositivo) dentro de un contexto dado. Es la respuesta exacta a la pregunta *¿Quién es el sujeto?* y se mantiene independiente de la cuenta técnica asignada.

• **Usuario:** Es la representación técnica y operativa de una identidad dentro de un sistema informático específico (cuentas del sistema operativo, credenciales de inicio, alias). Es el vehículo digital mediante el cual la entidad opera en los recursos locales.

• **Acceso (Autorización):** Define el alcance preciso de lo que el usuario está autorizado a realizar en el sistema (lectura, escritura, ejecución). Responde directamente a *¿Qué acciones tiene permitido ejecutar sobre los recursos del sistema?* y se regula mediante políticas de privilegios mínimos.

Responsabilidad Legal y Formalización de Cuentas:

La falta de formalización legal en el alta de usuarios representa una de las vulnerabilidades jurídicas y corporativas más graves. Todo usuario debe **firmar y manifestar su conformidad y aceptación de las responsabilidades, prohibiciones y condiciones** de uso antes de recibir acceso físico o lógico a los activos de la organización. Desde la perspectiva jurídica, 'lo que no está documentado, no existe'. En ausencia de un anexo firmado o un procedimiento documentado, la organización carece de respaldo legal para sancionar conductas negligentes o maliciosas, quedando desprovista de evidencia jurídica admisible en litigios laborales o demandas civiles.

2. Modelado Organizacional: Sanatorio Salud

Para simular un entorno real y aplicar los principios técnicos de IAM, utilizaremos la organización hipotética **'Sanatorio Salud'**, una clínica médica privada dedicada a la atención integral de pacientes. Esta organización maneja información altamente crítica y sensible, regulada por leyes de protección de datos personales de salud. Exige un diseño riguroso basado en el modelo de **Control de Acceso Basado en Roles (RBAC, *Role-Based Access Control*)**, donde los permisos se asocian a perfiles organizacionales (grupos) y los usuarios heredan los permisos al pertenecer a dichos roles.

Definición de Roles de la Clínica:

1. **admin_it:** Administrador técnico de infraestructura. Administra servidores, bases de datos y portales web de la clínica.
2. **medico:** Profesional médico responsable de la consulta asistencial directa y la evolución de los pacientes.
3. **auditor:** Analista encargado de auditar la calidad asistencial, procesos internos y generar métricas consolidadas.
4. **asistente:** Soporte administrativo y de recepción encargados del agendamiento y facturación de consultas.

Definición de Recursos en el Sistema de Archivos:

• `/datos/historias_clinicas` : Registros de salud de pacientes. Contienen datos médicos de extrema confidencialidad.
• `/datos/informes_auditoria` : Reportes consolidados y métricas operativas de calidad de la clínica.
• `/datos/agenda_turnos` : Calendario compartido de asignación de turnos y disponibilidad de consultorios.
• `/datos/portal_publico` : Información estática de horarios, folletos informativos y material institucional.

Matriz de Accesos de Recursos de la Organización:

Rol / Grupo	/historias_clinicas	/informes_auditoria	/agenda_turnos	/portal_publico
admin_it (TI)	---	r-x	rwx	rwx
medico (Médicos)	rwx	---	r-x	r-x
auditor (Auditoría)	---	rwx	r-x	r-x
asistente (Recepción)	---	---	rwx	r-x

Justificación y Criterios de Seguridad Aplicados:

• **Principio de Privilegio Mínimo:** Cada rol posee únicamente el acceso necesario para realizar sus funciones. Aunque el Administrador de TI tiene privilegios máximos en el portal, se le deniega el acceso a las historias clínicas (`---`), ya que un perfil técnico no requiere leer diagnósticos para mantener operativos los servidores.
• **Segregación de Funciones:** Se dividen las tareas críticas para evitar que una sola persona manipule todos los pasos de un proceso. El Auditor genera informes y tiene control total en auditorías (`rwx`), pero tiene vetado el historial médico directo para mantener la objetividad del análisis.
• **Necesidad de Conocer:** Los asistentes de recepción gestionan el calendario de citas (`rwx`) pero carecen de acceso a los informes médicos de los pacientes o métricas de calidad institucional, protegiendo datos sensibles contra incidentes o fugas de información.

3. Configuración del Laboratorio en VirtualBox

Para recrear este entorno corporativo con seguridad, implementaremos un laboratorio aislado utilizando **VirtualBox**. El uso de máquinas virtuales (VM) en ciberseguridad es fundamental, dado que proporciona un entorno controlado para simular incidentes, realizar configuraciones avanzadas de sistemas operativos y modelar políticas lógicas de accesos sin comprometer los sistemas de producción locales del anfitrión.

Requisitos y Configuración de VirtualBox:

1. **Máquina Virtual:** Instalar una máquina virtual con cualquier distribución de Linux (se recomienda Ubuntu Server, Debian o CentOS).
2. **Configuración de Red:** En los ajustes de la VM, seleccionar adaptador tipo 'Red Interna' o 'Solo-Anfitrión' (Host-Only). Esto asegura que los flujos de tráfico y servicios de autenticación de prueba queden estrictamente confinados dentro de la infraestructura aislada del hipervisor.
3. **Acceso a Terminal:** Iniciar la máquina virtual y abrir una consola terminal local o conectarse mediante un cliente seguro SSH.

[CAPTURA REQUERIDA] CONFIGURACIÓN DE RED Y VM EN VIRTUALBOX

Tome una captura de pantalla de la sección 'Red' o de la pantalla de inicio de su Máquina Virtual ejecutándose en VirtualBox y péguela en este espacio.

Creación de Recursos en Linux (Directorios de Trabajo):

Para simular los recursos del sistema de archivos, utilizaremos el comando de terminal `sudo mkdir -p` para crear la estructura jerárquica bajo la raíz del sistema de almacenamiento común en `/datos`:

```
# Crear directorios base de la organización
sudo mkdir -p /datos/historias_clinicas
sudo mkdir -p /datos/informes_auditoria
sudo mkdir -p /datos/agenda_turnos
sudo mkdir -p /datos/portal_publico
# Verificar la correcta creación de la estructura
ls -la /datos
```

4. Configuración de Identidades y Permisos en la Terminal

En sistemas basados en Linux, los roles de usuario (RBAC) se mapean lógicamente mediante la definición de **Grupos del Sistema**. A continuación, se detallan los comandos exactos para configurar los grupos correspondientes a cada rol organizativo y registrar los usuarios correspondientes en el sistema.

Paso A: Creación de Roles (Grupos):

```
# Crear grupos del sistema para cada rol corporativo
sudo groupadd admin_it
sudo groupadd medico
sudo groupadd auditor
sudo groupadd asistente
```

Paso B: Creación e Integración de Usuarios en Roles:

```
# Registrar cuentas de usuario en el sistema operativo
sudo useradd -m -s /bin/bash carlos_admin
sudo useradd -m -s /bin/bash elena_medico
sudo useradd -m -s /bin/bash pablo_auditor
sudo useradd -m -s /bin/bash sofia_asistente

# Asociar cada cuenta a su grupo/rol correspondiente (IAM RBAC)
sudo usermod -aG admin_it carlos_admin
sudo usermod -aG medico elena_medico
sudo usermod -aG auditor pablo_auditor
sudo usermod -aG asistente sofia_asistente
```

Paso C: Asignación de Propietarios y Permisos Octales a los Recursos:

Para garantizar la herencia de permisos de grupo en Linux, utilizaremos los comandos `chown` (para cambiar el grupo propietario del directorio) y `chmod` (para establecer los bits numéricos específicos del esquema de acceso):

```
# Cambiar el grupo propietario de cada directorio de recursos
sudo chown :admin_it /datos/portal_publico
sudo chown :medico /datos/historias_clinicas
sudo chown :auditor /datos/informes_auditoria
sudo chown :asistente /datos/agenda_turnos

# Aplicar permisos octales basados en la matriz de acceso aprobada
sudo chmod 770 /datos/historias_clinicas # Dueño/Grupo: rwx, Otros: ---
sudo chmod 750 /datos/informes_auditoria # Dueño/Grupo: rwx/rx, Otros: ---
sudo chmod 770 /datos/agenda_turnos # Dueño/Grupo: rwx, Otros: ---
sudo chmod 775 /datos/portal_publico # Dueño/Grupo: rwx/rx, Otros: r-x
```

[CAPTURA REQUERIDA] COMANDOS DE CREACIÓN DE USUARIOS Y GRUPOS

Tome una captura de su terminal tras haber ingresado los comandos de creación de grupos (sudo groupadd) y creación de usuarios y péguela en este recuadro.

5. Validación de Accesos y Diagnóstico

Para certificar que el sistema de control de accesos se comporta exactamente como se definió en la matriz RBAC, se debe iniciar sesión con los diferentes usuarios utilizando el comando `su - [usuario]` y ejecutar pruebas de lectura y escritura sobre los directorios.

```
# Iniciar sesión como Elena (Médico) y verificar permisos
su - elena_medico
id # Verificar grupos e identidades activas
cd /datos/historias_clinicas # Debería permitir el ingreso (Ok)
touch /datos/historias_clinicas/test.txt # Debería permitir la escritura (Ok)
cd /datos/informes_auditoria # Debería denegar el acceso (Permiso denegado)

# Iniciar sesión como Sofía (Asistente) y verificar restricciones
su - sofia_asistente
cd /datos/historias_clinicas # Debería fallar de inmediato (Denegado)
```

[CAPTURA REQUERIDA] PRUEBAS DE VALIDACIÓN DE PERMISOS (SU -)

Tome captura de la validación donde un usuario como sofia_asistente intente entrar a /datos/historias_clinicas y la consola devuelva 'Permission denied', demostrando el control liso.

6. Análisis de Riesgos de Permisos Incorrectos

Un error muy común en la práctica es asignar accesos genéricos o temporales para solucionar bloqueos rápidos sin evaluar el impacto.

PERMISO INCORRECTO: Grupo asistente con acceso rwx sobre /datos/historias_clinicas

Descripción del riesgo: Asignar control total de lectura y escritura de historias clínicas al personal de asistencia. Esto genera tres impactos graves alineados con la matriz de amenazas reales de ciberseguridad:

1. **Escalada de Privilegios (MITRE T1068 / Privilege Escalation):** Las credenciales del personal de recepción son las más expuestas a ataques de ingeniería social o phishing. Si una de estas cuentas es comprometida, un atacante externo hereda de inmediato control total sobre el recurso más valioso de la clínica sin requerir vulnerar sistemas avanzados.
2. **Vulneración de Confidencialidad de Datos Sensibles (NIST / Ley de Datos Personales):** Acceso a información protegida sin justificación médica, provocando contingencias de responsabilidad legal directa y millonarias multas operativas.
3. **Pérdida de Integridad Clínica:** Personal sin entrenamiento médico adquiere el poder de alterar o eliminar alergias, historiales o prescripciones, poniendo en riesgo letal y directo la vida física del paciente en consultas.

Checklist de Certificación de Laboratorio:

- ■ La máquina de VirtualBox está en una red aislada para evitar el alcance externo.
- ■ Los usuarios están asignados a sus grupos primarios correspondientes.
- ■ Se verificaron los permisos con el comando `ls -l /datos` y corresponden a los bits octales especificados.
- ■ Se probó y documentó la denegación de accesos incorrectos.